

AI Act High Risk Obligations

Requirements for providers and deployers of high-risk AI systems: Articles 9 to 15, provider and deployer obligations, conformity assessment. Regulation (EU) 2024/1689. Version of 29 September 2026.

Use of this document. Internal NormaAI summary for consultants, not legal advice. Check statements against the official text on EUR-Lex (CELEX 32024R1689) before advising a client. **Timing:** the obligations below apply to high-risk systems from **August 2026** (Annex III) and from **August 2027** for AI embedded in Annex I products.

1. Structure of the high-risk regime

Chapter III of the AI Act (Articles 6 to 49) contains the rules for high-risk AI systems. Section 2 (Articles 8 to 15) sets the **requirements the system itself must meet**. Section 3 (Articles 16 to 27) sets the **obligations of providers, deployers and other operators**. Section 5 (Articles 40 to 49) covers standards, conformity assessment, CE marking and registration. Articles 72 and 73 add post-market monitoring and serious incident reporting. How a system becomes high-risk is explained in the document [AI_Act_Risk_Classification](#).

Topic	Article	Addressed to
Compliance with the requirements, general	Art. 8	Provider
Risk management system	Art. 9	Provider
Data and data governance	Art. 10	Provider
Technical documentation	Art. 11 and Annex IV	Provider
Record keeping (logs)	Art. 12	Provider
Transparency and provision of information to deployers	Art. 13	Provider
Human oversight	Art. 14	Provider (design), deployer (use)
Accuracy, robustness and cybersecurity	Art. 15	Provider
Provider obligations, quality management system	Arts. 16, 17	Provider
Documentation keeping, log keeping, corrective actions	Arts. 18, 19, 20	Provider
Authorised representatives, importers, distributors	Arts. 22, 23, 24	Those operators
Responsibilities along the value chain	Art. 25	Any operator
Deployer obligations	Art. 26	Deployer
Fundamental rights impact assessment	Art. 27	Certain deployers
Conformity assessment, declaration, CE marking, registration	Arts. 43, 47, 48, 49	Provider
Post-market monitoring, serious incident reporting	Arts. 72, 73	Provider

Article 8 requires high-risk systems to comply with the requirements of Section 2, taking into account the intended purpose and the generally acknowledged state of the art. Where a product contains an AI system and is also covered by Annex I legislation, the provider is responsible for compliance with all applicable requirements and may integrate the testing and documentation into the documentation already required by

that legislation.

2. Risk management system (Article 9)

Providers must establish, implement, document and maintain a **risk management system** (Article 9(1)). It is a **continuous, iterative process planned and run throughout the entire lifecycle** of the system, with regular systematic review and updating (Article 9(2)).

The process comprises the following steps (Article 9(2)):

- **Identification and analysis** of the known and reasonably foreseeable risks to health, safety or fundamental rights when the system is used in accordance with its intended purpose.
- **Estimation and evaluation** of risks that may emerge when the system is used according to its intended purpose and under conditions of reasonably foreseeable misuse.
- **Evaluation of other risks** arising from analysis of data gathered by the post-market monitoring system (Article 72).
- **Adoption of appropriate and targeted risk management measures** to address the identified risks.

Further points to remember for client work:

- Only risks that can be reasonably mitigated or eliminated through the design, development or provision of technical information are in scope (Article 9(3)).
- Measures must aim to eliminate or reduce risks as far as technically feasible through design, then implement mitigation and control measures for risks that cannot be eliminated, and provide information and training to deployers (Article 9(5)). The residual risk must be judged acceptable.
- **Testing** is required to identify the most appropriate measures and to ensure the system performs consistently for its intended purpose. Testing takes place at any time during development and before placing on the market, against prior defined metrics and probabilistic thresholds (Article 9(6) to 9(8)). Testing in real-world conditions is possible under Article 60.
- Providers must consider whether the system is likely to have an **adverse impact on persons under 18 and other vulnerable groups** (Article 9(9)).
- Providers of systems already subject to internal risk management under other Union law may combine the processes (Article 9(10)).

3. Data and data governance (Article 10)

High-risk systems that use techniques involving the training of AI models with data must be developed on the basis of **training, validation and testing data sets** that meet the quality criteria in Article 10(2) to 10(5), when such data sets are used (Article 10(1)). Training, validation and testing data sets must be subject to data governance and management practices appropriate for the intended purpose (Article 10(2)). Those practices concern in particular:

- the relevant design choices;
- data collection processes and the origin of data, and for personal data, the original purpose of collection;
- relevant data preparation operations (annotation, labelling, cleaning, updating, enrichment, aggregation);
- the formulation of assumptions about what the data measure and represent;

- an assessment of the availability, quantity and suitability of the data sets needed;
- **examination in view of possible biases** likely to affect health and safety, negatively affect fundamental rights or lead to discrimination prohibited under Union law;
- appropriate measures to detect, prevent and mitigate possible biases;
- the identification of relevant data gaps or shortcomings that prevent compliance, and how they can be addressed.

Data sets must be **relevant, sufficiently representative and, to the best extent possible, free of errors and complete** in view of the intended purpose. They must have appropriate statistical properties, including as regards the persons or groups on whom the system is intended to be used (Article 10(3)). They must take into account the characteristics or elements particular to the specific geographical, contextual, behavioural or functional setting in which the system is intended to be used (Article 10(4)).

Special categories of personal data. Article 10(5) allows providers to process special categories of personal data to the extent strictly necessary for bias detection and correction, subject to safeguards such as technical limits on re-use, pseudonymisation, access controls, deletion once the bias is corrected, and documentation of why the processing was strictly necessary.

For systems that do not train models, Article 10(2) to 10(5) apply only to the testing data sets (Article 10(6)).

4. Technical documentation (Article 11 and Annex IV)

Technical documentation must be drawn up **before the system is placed on the market or put into service** and must be kept up to date (Article 11(1)). It must demonstrate that the system complies with the requirements of Section 2 and give national competent authorities and notified bodies the information needed to assess compliance.

The minimum elements are set out in **Annex IV**. They include:

- a general description of the system: intended purpose, provider name, version, how it interacts with hardware or software, versions of relevant software and firmware, forms in which it is placed on the market, user interface, instructions for use;
- a detailed description of the elements of the system and its development process: methods and steps for development, design specifications, system architecture, computational resources, data requirements including data sheets, human oversight assessment, pre-determined changes, validation and testing procedures with metrics, cybersecurity measures;
- detailed information about monitoring, functioning and control, including the system's capabilities and limitations and the accuracy levels for specific persons or groups;
- a description of the appropriateness of the performance metrics;
- a detailed description of the **risk management system** under Article 9;
- a description of relevant changes made by the provider through the lifecycle;
- a list of the harmonised standards applied, or a description of other solutions used;
- a copy of the **EU declaration of conformity**;
- a detailed description of the **post-market monitoring system**, including the post-market monitoring plan.

SMEs and start-ups may provide the Annex IV elements in a simplified manner using a form to be established by the Commission (Article 11(1), second subparagraph). Providers of systems covered by Annex I legislation draw up a single set of technical documentation containing all the information required (Article 11(2)).

5. Record keeping (Article 12)

High-risk systems must technically allow for the **automatic recording of events (logs) over the lifetime of the system** (Article 12(1)). The logging capability must enable the recording of events relevant for:

- identifying situations that may result in the system presenting a risk, or in a substantial modification (Article 12(2)(a));
- facilitating post-market monitoring under Article 72 (Article 12(2)(b));
- monitoring the operation of the system by deployers under Article 26(5) (Article 12(2)(c)).

For remote biometric identification systems listed in Annex III, point 1(a), logs must at a minimum record the period of each use (start and end date and time), the reference database against which input data was checked, the input data for which the search led to a match, and the identification of the natural persons involved in the verification of results (Article 12(3)).

5.1 How long records must be kept

What	Who	Minimum duration	Article
Automatically generated logs	Provider, to the extent under its control	At least six months , unless Union or national law (for example data protection law) provides otherwise	Art. 19
Automatically generated logs	Deployer, to the extent under its control	At least six months , unless otherwise provided	Art. 26(6)
Technical documentation, quality management system documentation, notified body decisions, EU declaration of conformity	Provider	10 years after the system has been placed on the market or put into service	Art. 18

6. Transparency and information to deployers (Article 13)

High-risk systems must be designed and developed so that their operation is **sufficiently transparent to enable deployers to interpret the output and use it appropriately** (Article 13(1)). The system must come with **instructions for use** in an appropriate digital or other format, with concise, complete, correct and clear information that is relevant, accessible and comprehensible to deployers (Article 13(2)).

The instructions for use must contain at least (Article 13(3)):

- the identity and contact details of the provider and, where applicable, of its authorised representative;
- the characteristics, capabilities and limitations of performance: intended purpose; the level of accuracy, robustness and cybersecurity against which the system has been tested and validated; known or foreseeable circumstances that may lead to risks; the technical capabilities to provide information relevant to explain its output; performance regarding specific persons or groups; specifications for input data;
- changes to the system and its performance that have been pre-determined by the provider at the moment of the initial conformity assessment;

- the **human oversight measures** under Article 14, including the technical measures put in place to facilitate the interpretation of outputs;
- the computational and hardware resources needed, the expected lifetime and necessary maintenance and care measures;
- where relevant, a description of the mechanisms included in the system that allow deployers to collect, store and interpret the logs (Article 12).

This Article 13 duty is about information from the provider to the deployer. It is different from the transparency duties towards end users under Article 50, which are covered in the document [AI_Act_Transparency_Requirements](#).

7. Human oversight (Article 14)

High-risk systems must be designed and developed, including with appropriate human-machine interface tools, so they can be **effectively overseen by natural persons** during the period in which they are in use (Article 14(1)). The aim is to prevent or minimise risks to health, safety or fundamental rights that persist despite the other requirements (Article 14(2)). Oversight measures must be commensurate with the risks, the level of autonomy and the context of use (Article 14(3)). They are built into the system by the provider where technically feasible, or identified by the provider for implementation by the deployer.

The system must enable the persons assigned to oversight, as appropriate and proportionate, to (Article 14(4)):

- properly **understand the relevant capacities and limitations** of the system and duly monitor its operation, including to detect and address anomalies, dysfunctions and unexpected performance;
- remain aware of the possible tendency of **automatically relying or over-relying on the output** (automation bias), in particular for systems used to provide information or recommendations for decisions by natural persons;
- correctly **interpret the output**, taking into account the interpretation tools and methods available;
- decide, in any particular situation, **not to use the system or to disregard, override or reverse the output**;
- **intervene in the operation** of the system or interrupt it through a "stop" button or a similar procedure that allows the system to come to a halt in a safe state.

For remote biometric identification systems (Annex III, point 1(a)), no action or decision may be taken by the deployer on the basis of an identification unless it has been **separately verified and confirmed by at least two natural persons** with the necessary competence, training and authority (Article 14(5)). Exceptions exist for law enforcement, migration, border control or asylum where Union or national law considers this requirement disproportionate.

8. Accuracy, robustness and cybersecurity (Article 15)

High-risk systems must be designed and developed to achieve an **appropriate level of accuracy, robustness and cybersecurity**, and to perform consistently in those respects throughout their lifecycle (Article 15(1)).

- **Accuracy**: the levels of accuracy and the relevant accuracy metrics must be declared in the accompanying instructions for use (Article 15(3)). The Commission encourages benchmarks and measurement methodologies (Article 15(2)).

- **Robustness:** systems must be as resilient as possible regarding errors, faults or inconsistencies that may occur within the system or its environment, in particular through interaction with natural persons or other systems. Technical redundancy solutions, such as backup or fail-safe plans, may be used (Article 15(4)).
- **Feedback loops:** systems that continue to learn after being placed on the market must be developed so as to eliminate or reduce as far as possible the risk of biased outputs influencing input for future operations, and to address such loops with appropriate mitigation measures (Article 15(4)).
- **Cybersecurity:** systems must be resilient against attempts by unauthorised third parties to alter their use, outputs or performance by exploiting vulnerabilities. Technical solutions must address AI-specific vulnerabilities, including measures to prevent, detect, respond to, resolve and control for attacks trying to manipulate the training data set (**data poisoning**) or pre-trained components (**model poisoning**), inputs designed to cause the model to make a mistake (**adversarial examples or model evasion**), **confidentiality attacks** and model flaws (Article 15(5)).

9. Obligations of providers (Articles 16 to 24)

Beyond the requirements on the system, Article 16 lists what a provider of a high-risk system must do:

- ensure the system complies with Section 2 (Articles 8 to 15);
- indicate its name, registered trade name or trademark and contact address on the system, its packaging or accompanying documentation;
- have a **quality management system** in place that complies with Article 17;
- keep the documentation referred to in Article 18 and the logs referred to in Article 19;
- ensure the system undergoes the relevant **conformity assessment procedure** (Article 43) before being placed on the market or put into service;
- draw up an **EU declaration of conformity** (Article 47) and affix the **CE marking** (Article 48);
- comply with the **registration obligations** in Article 49(1);
- take necessary **corrective actions** and provide information as required by Article 20 when the system is not in conformity;
- demonstrate conformity on the reasoned request of a national competent authority;
- ensure the system complies with **accessibility requirements** under Directives (EU) 2016/2102 and (EU) 2019/882.

Quality management system (Article 17). It must be documented in a systematic and orderly manner through written policies, procedures and instructions. It covers, among other things: a strategy for regulatory compliance; techniques for design, development, quality control and quality assurance; examination, test and validation procedures; technical specifications and standards; data management systems and procedures; the risk management system; post-market monitoring; serious incident reporting procedures; communication with authorities; record keeping; resource management; and an accountability framework. Implementation is proportionate to the size of the provider's organisation. Providers of financial services already subject to internal governance rules meet most of this through those rules.

Corrective actions and duty of information (Article 20). A provider that considers or has reason to consider that a high-risk system is not in conformity must immediately take the corrective actions needed to bring it into conformity, withdraw it, disable it or recall it, and inform distributors, deployers, the authorised representative and importers. If the system presents a risk, the provider must investigate and

inform the market surveillance authorities.

Authorised representatives, importers and distributors (Articles 22 to 24). Providers established in third countries must appoint an EU authorised representative by written mandate before making a high-risk system available in the Union (Article 22). Importers must verify, before placing a system on the market, that conformity assessment was carried out, technical documentation exists, CE marking is affixed and the authorised representative is appointed (Article 23). Distributors carry out verification before making a system available (Article 24).

Responsibilities along the value chain (Article 25). Any distributor, importer, deployer or third party is considered a **provider of a high-risk system** and takes on the provider obligations if it (a) puts its name or trademark on a high-risk system already on the market, (b) makes a substantial modification to a high-risk system so that it remains high-risk, or (c) modifies the intended purpose of an AI system, including a general-purpose AI system, so that it becomes high-risk. The initial provider must cooperate and provide the information needed.

10. Obligations of deployers (Articles 26 and 27)

Deployers of high-risk systems must (Article 26):

- take appropriate **technical and organisational measures** to use the system in accordance with the instructions for use (Art. 26(1));
- assign **human oversight to natural persons who have the necessary competence, training, authority and support** (Art. 26(2));
- to the extent the deployer exercises control over **input data**, ensure it is relevant and sufficiently representative for the intended purpose (Art. 26(4));
- **monitor the operation** of the system on the basis of the instructions for use, and inform the provider and, where relevant, authorities and stop the use if they have reason to consider the system presents a risk or when a serious incident has occurred (Art. 26(5));
- **keep the logs** automatically generated, to the extent under their control, for at least six months (Art. 26(6));
- before putting into service or using a system at the workplace, **inform workers' representatives and the affected workers** that they will be subject to the system (Art. 26(7));
- where the deployer is a public authority or a Union institution, register the use in the EU database (Art. 26(8));
- use the information provided under Article 13 to carry out a **data protection impact assessment** under the GDPR where applicable (Art. 26(9));
- inform natural persons that they are subject to the use of a high-risk system when it takes or assists in decisions concerning them (Art. 26(11));
- cooperate with the competent authorities (Art. 26(12)).

Fundamental rights impact assessment (Article 27). Before deploying a high-risk system, deployers that are **bodies governed by public law or private entities providing public services**, and deployers of systems used for creditworthiness evaluation and credit scoring (Annex III, point 5(b)) or for risk assessment and pricing in life and health insurance (Annex III, point 5(c)), must assess the impact on fundamental rights. The assessment describes the processes in which the system will be used, the period and frequency of use, the categories of persons affected, the specific risks of harm, the human oversight measures and the measures to take if risks materialise. The result is notified to the market surveillance

authority.

Right to explanation (Article 86). A person subject to a decision taken by a deployer on the basis of the output of an Annex III high-risk system that produces legal effects or similarly significantly affects them, in a way they consider to adversely affect their health, safety or fundamental rights, has the right to obtain from the deployer clear and meaningful explanations of the role of the system in the decision-making procedure and the main elements of the decision.

11. Conformity assessment (Articles 43, 47, 48 and 49)

Conformity assessment is the process of demonstrating that the requirements of Section 2 have been met. It must be completed **before the system is placed on the market or put into service**. The applicable procedure depends on the type of system (Article 43).

System	Procedure	Notified body?
Annex III, point 1 (biometrics) , where the provider has applied harmonised standards or common specifications in full	Provider chooses between internal control (Annex VI) and an assessment of the quality management system and technical documentation with a notified body (Annex VII).	Optional
Annex III, point 1, where harmonised standards do not exist, were not applied in full, or common specifications exist and were not applied	The Annex VII procedure with a notified body.	Required
Annex III, points 2 to 8 (critical infrastructure, education, employment, essential services, law enforcement, migration, justice and democratic processes)	Internal control (Annex VI). No notified body involvement. The provider verifies its quality management system, examines the technical documentation and checks the design and monitoring process.	No
High-risk AI in Annex I products	The conformity assessment procedure required by the relevant sectoral legislation, with the Section 2 requirements integrated into that assessment.	As set by the sectoral law

- **Substantial modification:** a new conformity assessment is required each time the system undergoes a substantial modification. Changes to a system that continues to learn after placing on the market, when pre-determined by the provider at the initial assessment and documented in the technical documentation, are not a substantial modification (Article 43(4)).
- **EU declaration of conformity (Article 47):** the provider draws up a written, machine-readable, signed declaration for each system, keeps it for 10 years and provides it to authorities on request. It states that the requirements of Section 2 are met, and it follows Annex V.
- **CE marking (Article 48):** affixed visibly, legibly and indelibly, or digitally for digital-only systems, with the identification number of the notified body where one was involved.
- **Registration (Article 49 and Article 71):** before placing on the market or putting into service, the provider registers itself and the system in the **EU database for high-risk AI systems**. This includes Annex III systems the provider has assessed as not high-risk under Article 6(3).
- **Notified bodies** (Articles 28 to 39) are conformity assessment bodies designated by Member States. They must be independent and impartial.

12. After the market launch: monitoring and incidents (Articles 72 and 73)

Post-market monitoring (Article 72). Providers must establish and document a post-market monitoring system, proportionate to the nature of the technology and the risks, that actively and systematically collects, documents and analyses relevant data on performance throughout the lifetime of the system. It is based on a post-market monitoring plan that is part of the technical documentation.

Serious incident reporting (Article 73). Providers must report any serious incident to the market surveillance authorities of the Member States where it occurred, immediately after establishing a causal link or its reasonable likelihood and in any event **not later than 15 days** after becoming aware. The deadline is shortened to **2 days** for a widespread infringement or a serious incident involving disruption of critical infrastructure, and to **10 days** in the event of the death of a person.

13. Frequently asked questions

What documentation must a provider keep, and for how long?

Technical documentation (Article 11), quality management system documentation, decisions of notified bodies and the EU declaration of conformity must be kept for 10 years after the system is placed on the market or put into service (Article 18). Automatically generated logs must be kept at least six months (Article 19 for providers, Article 26(6) for deployers).

Do deployers have obligations if they did not build the system?

Yes. Deployers must follow the instructions for use, assign competent human oversight, monitor the system, keep logs, inform workers and affected persons, and in some cases carry out a fundamental rights impact assessment (Articles 26 and 27).

Is a notified body always needed?

No. For Annex III points 2 to 8, providers use internal control (Annex VI). A notified body is needed for biometric systems under Annex III point 1 when harmonised standards were not fully applied, and where sectoral law for Annex I products requires it.

When does a client that customises a third-party AI tool become a provider?

When it puts its own name or trademark on a high-risk system, makes a substantial modification, or changes the intended purpose so that the system becomes high-risk (Article 25). It then takes on all provider obligations.

When do these obligations apply?

Following the timeline of the NormaAI brief, the obligations for high-risk systems apply from August 2026 and those for AI embedded in Annex I products from August 2027 (Article 113). Clients should start with a gap analysis, documentation, risk management set-up and data governance work, and verify the dates on EUR-Lex.

14. Sources

- Regulation (EU) 2024/1689, Articles 8 to 27, 43 to 49, 72, 73, 86 and Annexes IV, V, VI and VII, EUR-Lex, CELEX 32024R1689.
- European Commission, AI Act published summaries and guidance, digital-strategy.ec.europa.eu.